# Idarti Strategic Project Organization and Technical Roadmap: A Comprehensive Blueprint for Next-Generation Decentralized and Agentic Cybersecurity Infrastructure

## Executive Summary

The cybersecurity industry stands at a critical inflection point, characterized by the simultaneous collapse of centralized vulnerability intelligence infrastructures and the exponential expansion of the threat surface via the Internet of Things (IoT). As the National Vulnerability Database (NVD) struggles to analyze over 93% of new incoming Common Vulnerabilities and Exposures (CVEs), the industry faces a dangerous intelligence vacuum.[1] Concurrently, the IoT market is projected to surge to $142 billion by 2030, introducing billions of unsecured endpoints into critical infrastructure and consumer environments.[1]
Idarti serves as a strategic response to these systemic failures. This report outlines a comprehensive project organization plan for building Idarti, a cutting-edge cybersecurity platform leveraging Google Cloud Platform (GCP) credits. The platform is architected around three novel pillars: a Decentralized Physical Infrastructure Network (DePIN) for IoT security using Zero-Knowledge proofs; an Agentic AI system for automated CVE triage; and an autonomous "SOC-in-a-box" evolving the Kali Purple defensive framework.
This document serves as a master plan for a bootstrapped, capital-efficient entity. It navigates the complex geopolitical landscape of a Czech-founded company seeking global relevance, addressing the structural barriers of US government contracting through a "services-first" revenue model and a "sovereign-cloud" technical architecture. By synthesizing the immutable trust of decentralized ledgers with the adaptive reasoning of Large Language Models (LLMs), Idarti positions itself not merely as a tool provider, but as a foundational infrastructure layer for the autonomous future of digital defense.

---

## Chapter 1: Strategic Context and Market Dynamics

To engineer a resilient project organization plan, one must first rigorously analyze the boundary conditions—financial, regulatory, and technical—that define the operating environment. For Idarti, these conditions are defined by the "Bootstrapped Specialist" paradigm and the geopolitical friction of cross-border cybersecurity.

## 1.1 The Collapse of Centralized Vulnerability Intelligence

The cybersecurity ecosystem has long relied on centralized authorities to aggregate and validate threat intelligence. The current crisis at the NVD represents a structural failure of this model. With submission volumes increasing by 32% year-over-year, the centralized resource allocation model has proven unable to scale, leaving the vast majority of new vulnerabilities unanalyzed and unprioritized.[1] This creates a "fog of war" where organizations cannot accurately assess their risk exposure.

This failure is particularly acute in the IoT sector. The existing sources of IoT vulnerability data are fragmented, with inconsistent coverage across the NVD (which lacks specific IoT categorization) and discontinued community databases like exploitee.rs.[1] The market requires a mechanism that decouples vulnerability reporting from centralized validation bottlenecks. Idarti's proposed DePIN ledger addresses this by distributing the validation workload across a decentralized network of researchers and devices, incentivized to maintain an immutable record of security posture.

## 1.2 The "Bootstrapped Specialist" Financial Model

Idarti's inception is defined by extreme capital efficiency. Starting with approximately $1,250 in Google Cloud credits (with a pathway to $2,000 via the Start Tier), the project cannot adopt the "growth at all costs" strategies typical of Venture Capital-backed entities.[1] Instead, the analysis points to the "bootstrapping with services" model as the most viable path to sustainability.

This model, validated by successful exits such as Osprey Security and Sucuri, essentially uses high-margin consulting revenues to subsidize product R&D.[1] The strategic implication is that Idarti must operate as a hybrid entity:

- **The Services Arm:** A high-end consultancy providing penetration testing, vCISO services, and SOC 2 readiness to generate immediate cash flow ($5,000 - $15,000 per month targets).[1]
- **The Product Arm:** A lean software development unit utilizing the surplus cash and cloud credits to build the automated platform.

This dual structure serves a secondary purpose: the consulting engagements act as a "living laboratory." The Idarti product—specifically the Agentic AI triage and the SOC-in-a-box—can be deployed internally on client engagements before public release. This ensures that the product is battle-tested in real-world environments, creating a tight feedback loop between the "operator" (the consultant) and the "engineer" (the developer).

## 1.3 Geopolitical Regulatory Barriers (ITAR and FOCI)

A critical finding in the strategic analysis is the structural barrier facing a Czech-owned entity in the US defense market. Despite the close NATO alliance, US regulations regarding Foreign Ownership, Control, or Influence (FOCI) create significant friction.

The formation of a US LLC (e.g., in Wyoming) provides a legal container for commercial transactions and banking but does *not* resolve the FOCI issues for classified or sensitive

government contracts.[1] ITAR (International Traffic in Arms Regulations) restricts access to technical data related to defense articles to "US Persons" (citizens or permanent residents). Furthermore, facility security clearances are effectively unavailable to foreign-owned entities without complex and expensive mitigation agreements (requiring independent boards and proxy holders) that are infeasible for an early-stage startup.[1]
Consequently, the project organization plan must explicitly bifurcate its Go-to-Market (GTM) strategy:

1. **US Strategy:** Focus exclusively on the *commercial* market (B2B SaaS) and non-sensitive state/local government contracts that do not require security clearances. The Wyoming LLC serves as the billing entity to reduce friction for US corporate buyers.[1]
2. **EU Strategy:** Leverage the "European Sovereignty" narrative. As a Czech entity, Idarti has preferential access to European Defence Agency (EDA) programs and NATO CCDCOE initiatives, which are increasingly prioritizing indigenous European cyber capabilities to reduce reliance on non-EU providers.[1]

### 1.4 Market Opportunities: The "Slop" and the "Gap"

The project targets two distinct market inefficiencies:

- **The "Slop" (Bug Bounty Noise):** The bug bounty market is plagued by low-quality submissions, often generated by basic LLMs. Platforms report that 50-70% of submissions are invalid, creating a massive operational burden for program managers.[1] Idarti's Agentic AI pillar aims to filter this noise with high-precision, autonomous triage.
- **The "Gap" (Mid-Market SOC):** Small and Medium Enterprises (SMEs) face enterprise-class threats but lack the budget for 24/7 human SOCs. The "SOC-in-a-box" pillar democratizes advanced defense by replacing the Level 1 human analyst with an autonomous software agent.

---

## Chapter 2: Pillar I - The DePIN IoT Security Ledger

The first technological pillar of Idarti is the Decentralized IoT Security Ledger. This system is designed to provide a "single source of truth" for the security state of IoT devices, independent of the manufacturer's self-reporting or the NVD's backlog.

### 2.1 Theoretical Foundation: DePIN and Trust Minimization

Decentralized Physical Infrastructure Networks (DePIN) utilize cryptographic incentives to crowdsource physical infrastructure. In Idarti's case, the "infrastructure" is the global web of device vulnerability data. The core value proposition is censorship resistance and auditability. In a centralized model, a manufacturer might pressure a vulnerability database to delay disclosure to protect their stock price. In the Idarti DePIN model, the ledger is immutable. Once a vulnerability proof is verified and anchored, it cannot be erased. This forces a transparency that aligns with the "Security by Design" principles of the EU Cyber Resilience Act.1

## 2.2 Consensus Architecture: The DAG Model

Given the high throughput requirements of IoT (billions of devices potentially reporting "heartbeats"), a traditional linear blockchain (like Bitcoin or Ethereum) is unsuitable due to latency and transaction fees. Idarti will implement a **Directed Acyclic Graph (DAG)** architecture, conceptually similar to IOTA's Tangle or Nano's Block Lattice.

| Feature | Blockchain | DAG (Idarti Model) | Rationale for IoT |
|---|---|---|---|
| **Topology** | Linear Chain | Directed Graph | Allows parallel processing of transactions; essential for handling thousands of device attestations per second. |
| **Fees** | High (Gas) | Zero / Negligible | IoT devices transmit micro-data; even a $0.01 fee per transaction makes the economics unviable. |
| **Miners** | External Validators | Users (Devices) | In a DAG, the device issuing a transaction validates two previous transactions, removing the need for a rent-seeking miner class. |
| **Scalability** | Decreases with load | Increases with load | As more devices join and validate each other, the network's throughput capacity grows. |

## 2.3 Zero-Knowledge Proofs (ZKPs) for Privacy-Preserving Attestation

A major hurdle in IoT security is the protection of intellectual property and user privacy. A manufacturer cannot simply publish their firmware source code for verification. Idarti solves this using **Zero-Knowledge Proofs (ZKPs)**, specifically utilizing **zk-SNARKs** (Zero-Knowledge Succinct Non-Interactive Argument of Knowledge).

### 2.3.1 The "Proof of Security" Protocol

The protocol enables a device (the Prover) to prove to the network (the Verifier) that it is secure without revealing its internal state.

- **Circuit Logic:** The ZK circuit takes as input:

    - *Public Inputs:* The hash of the current firmware, a list of Merkle roots representing known vulnerability signatures (CVEs).
    - *Private Inputs:* The actual firmware binary (or a trusted execution environment attestation), the device's private identity key.
- **The Assertion:** The circuit computes that the firmware hash matches the trusted hash AND that the binary does not contain the signatures of the known CVEs.
- **The Output:** A small cryptographic proof (approx. 200-300 bytes) that verifies the assertion is true.
- **Privacy Preservation:** The network sees only the proof. It does not see the firmware code, ensuring the manufacturer's IP is safe. It does not see the specific user configuration, ensuring GDPR compliance.

### 2.4 Integration with Regulatory Frameworks

The ledger is engineered to serve as a compliance engine for emerging regulations.

- **US Cyber Trust Mark:** This voluntary labeling program (launched 2025) requires devices to meet specific cybersecurity criteria.[1] The Idarti Ledger can act as the dynamic backend for the physical QR code on the device. A consumer scans the code, and the app queries the ledger for the latest ZK proof. If the device hasn't posted a "clean" proof in the last 30 days, the Trust Mark shows as "Expired" on the consumer's phone.
- **EU Cyber Resilience Act (CRA):** The CRA mandates that manufacturers provide security updates for the expected product lifetime.[1] The ledger provides an immutable audit trail of these updates. If a manufacturer abandons a product, the ledger records the cessation of updates, providing irrefutable evidence for regulators or class-action lawsuits.

### 2.5 Technical Implementation on GCP

While the protocol is decentralized, Idarti's *infrastructure* for interacting with it is hosted on Google Cloud to ensure high availability for API consumers.

- **Ledger Nodes:** Hosted on **Cloud Run** containers. These nodes participate in the DAG, gossiping transactions and validating proofs.
- **Indexing Layer:** To make the ledger queryable (e.g., "Show me all secure cameras in Germany"), Idarti uses a "Layer 2" indexer. Ledger events are streamed via **Pub/Sub** into **BigQuery**.
- **Storage:** The heavy data (full vulnerability reports, firmware binaries for authorized auditors) is stored in **Cloud Storage**, with only the content-addressable hashes stored on-chain to maintain efficiency.

---

## Chapter 3: Pillar II - Agentic AI for Automated CVE Triage

The second pillar addresses the operational bottleneck of vulnerability management. The "Slop" problem—the deluge of low-quality, AI-generated vulnerability reports—threatens to overwhelm security teams. Idarti's solution is **Agentic AI**: a system that does not just "read and summarize" but "plans and acts."

## 3.1 The Agentic Cognitive Architecture

Unlike a standard chatbot, an Agentic system operates on a cognitive loop, often described as the **ReAct (Reason + Act)** pattern.

1. **Input Analysis:** The agent receives a raw vulnerability report (e.g., from a bug bounty platform or an internal scan).
2. **Reasoning & Planning:** The agent analyzes the claim.
    - *Thought:* "The report claims a SQL injection on the /login endpoint. To verify this, I need to construct a safe payload that triggers a time delay but does not destroy data."
    - *Plan:* "1. Check if the endpoint is reachable. 2. Send baseline request. 3. Send payload ' OR SLEEP(5)--. 4. Measure response time."
3. **Action (Tool Use):** The agent executes the plan using a sandboxed environment. It calls a curl tool or a headless browser driver.
4. **Observation:** The agent perceives the result. "Response time was 5005ms."
5. **Reflection:** "The delay matches the sleep command. This confirms the vulnerability."
6. **Final Output:** The agent marks the report as "Verified Critical" and generates a reproduction script for the human engineer.

## 3.2 Economic Modeling with Gemini Flash-Lite

A critical constraint for Idarti is the cost of inference. Using a high-end model like Gemini Pro for every triage would burn through the $1,250 credit allocation rapidly. The strategy relies on **Model Cascading**.[1]

- **Tier 1: The Filter (Gemini Flash-Lite)**
    - **Function:** Rapidly discard spam, nonsense, and out-of-scope reports.
    - **Cost:** ~$0.25 per 1 million tokens.
    - **Throughput:** High.
    - **Logic:** If the report does not contain a coherent attack vector, reject immediately.
- **Tier 2: The Planner (Gemini Pro)**
    - **Function:** complex reasoning and plan generation for reports that pass the filter.
    - **Cost:** Higher, but applied to <30% of traffic.
- **Tier 3: The Executor (Sandboxed Scripts)**
    - **Function:** Running the code.
    - **Cost:** Compute time on Cloud Run (very low).

**Financial Implication:** This tiered approach reduces the blended cost per triage to approximately $0.05 - $0.10. If Idarti charges a customer $2.00 per valid triage or a flat subscription, the margins are exceptionally high (>90%), fitting the bootstrapped requirement for cash efficiency.

### 3.3 Vector-Based Deduplication Strategy

A major pain point in bug bounties is duplicate reporting. Keyword matching fails when researchers use different terminology (e.g., "XSS" vs "Script Injection"). Idarti employs **Semantic Deduplication**.

- **Mechanism:** Every incoming report is passed through an embedding model (e.g., Gecko on Vertex AI) to generate a high-dimensional vector representing its semantic meaning.
- **Storage:** These vectors are stored in **BigQuery** using its Vector Search capabilities.
- **Query:** New reports are queried against the database using Cosine Similarity.
- **Insight:** If a new report has a similarity score > 0.95 with an existing resolved ticket, the agent flags it as a duplicate automatically, citing the original ticket ID. This solves the "duplicate noise" problem that plagues 60%+ of program management time.[1]

---

# Chapter 4: Pillar III - Autonomous 'SOC-in-a-Box'

The third pillar targets the underserved SME market. The concept evolves "Kali Purple"—an OS for defensive security—into a cloud-native, autonomous service.

### 4.1 The Concept: Autonomic Security Operations

The goal is to build a system that manages itself. The "SOC-in-a-box" acts as a digital immune system, continuously monitoring, detecting, and responding to threats without human intervention for Level 1 and Level 2 incidents.

### 4.2 Technical Architecture: The Blue Team Stack

The defensive stack is built on open-source components wrapped in Google Cloud infrastructure to ensure scalability and low cost.

- **Endpoint Telemetry (Wazuh):** Idarti deploys Wazuh agents to client servers and workstations. Wazuh provides file integrity monitoring, log analysis, and vulnerability detection.
- **Data Ingestion (Cloud Run + Pub/Sub):** Agent logs are streamed to a Cloud Run collector, which buffers them into Pub/Sub. This decoupling ensures that a log spike (e.g., during a DDoS attack) does not crash the analysis engine.
- **Detection Engine (Vertex AI + BigQuery):** Instead of a traditional SIEM (which is expensive), Idarti uses BigQuery as a data lake. Scheduled queries (SQL) and Vertex AI anomaly detection models scan the logs for threats.
- **Response (Cloud Functions):** When a threat is detected (e.g., "Brute force attack on SSH"), a Cloud Function is triggered. It interacts with the GCP API to:
    - Update **Cloud Armor** rules to block the source IP.[1]
    - Isolate the compromised VM by detaching its network interface.
    - Trigger a snapshot for forensics.

### 4.3 The Red Team Module: Continuous Automated Red Teaming (CART)

To ensure the Blue Team is effective, the system must constantly test itself. This is the "Red" component of the Kali Purple evolution.

- **Automated Adversary Emulation:** The system uses the **Agentic AI** (from Pillar II) to launch safe, simulated attacks against the client's infrastructure.
- **Use Case:** The Red Agent attempts to upload a "web shell" (which is actually a harmless test file) to a web server.
- **Verification:** The system checks if the Blue Team module detected the upload.
    - *If Detected:* The test passes.
    - *If Missed:* The system generates a "Gap Report" and creates a ticket to update the detection rules.
- **Value:** This moves security from "Point-in-Time" (annual pen test) to "Continuous" assurance.

---

# Chapter 5: Cloud Infrastructure and Cost Engineering

Building this three-pillar platform on a $1,250 budget requires aggressive architectural discipline. The guiding principle is **"Scale-to-Zero."** If no one is using the service, the cost should be near zero.

### 5.1 Service Selection Matrix: The "Credit Burner" Avoidance Strategy

The business plan identifies specific GCP services that are dangerous for bootstrapped startups ("Credit Burners") and proposes alternatives.[1]

| Component | "Credit Burner" (Avoid) | "Bootstrapper Friendly" (Select) | Cost Rationale |
|---|---|---|---|
| **Compute** | **GKE Standard Clusters** | **Cloud Run** | GKE has a management fee ($74/mo) + idle node costs. Cloud Run charges only for request processing time (100ms granularity). |
| **Database** | **Cloud SQL (Always On)** | **BigQuery / Firestore** | Cloud SQL incurs hourly costs even when idle. BigQuery offers 1TB/month of free queries; Firestore charges by document |

| | | | |
|---|---|---|---|
| | | | read/write. |
| **AI** | **Gemini Ultra / Pro (Exclusively)** | **Gemini Flash-Lite** | Flash-Lite is 50-100x cheaper and sufficient for 90% of triage tasks. Pro is reserved for complex reasoning. |
| **Security** | **Security Command Center Premium** | **Open Source (Wazuh) + Standard Tier** | SCC Premium is enterprise-priced ($15k+). Open source tools hosted on Cloud Run provide similar functionality for a fraction of the cost. |
| **SIEM** | **Chronicle / Splunk** | **BigQuery Log Analytics** | Building a custom SIEM on BigQuery leverages the free tier and avoids the massive licensing fees of commercial SIEMs. |

## 5.2 The "AI Scale" Tier Strategy

The ultimate goal of the infrastructure design is not just to save money, but to qualify for the **Google for Startups "AI Scale" Tier**, which offers **$350,000** in credits over two years.[1]

- **Requirement:** The startup must use Vertex AI as the core product foundation.
- **Idarti Alignment:** By making Gemini the central "brain" of both the Triage Agent and the SOC-in-a-box (rather than just a side feature), Idarti maximizes its eligibility. The architecture is designed to demonstrate "AI-Native" workflow, where the AI is performing work equivalent to human FTEs (Full-Time Employees).

## 5.3 Sovereign Cloud Architecture for Regulatory Compliance

To address the FOCI and GDPR requirements, the infrastructure is defined using **Terraform** (Infrastructure as Code) with strict locality constraints.

- **US Workspace:** A dedicated GCP Project hosted in us-central1, owned by the Wyoming LLC. Handles all US commercial data.
- **EU Workspace:** A dedicated GCP Project hosted in europe-west3 (Frankfurt), owned by the Czech entity. Handles all European defense and GDPR-sensitive data.
- **Isolation:** There is no VPC peering between these environments. Data flows only via the public API, ensuring strict legal separation of data residency.

---

# Chapter 6: Operational Roadmap and Project

# Organization

The execution plan follows a strict chronological phases, balancing the need for immediate revenue (Survival) with the long-term vision of the platform (Growth).

## 6.1 Phase 1: Foundation and Validation (Months 1-6)

- **Objective:** Establish legal entities and generate initial cash flow.
- **Legal Actions:**
  - Form **Wyoming LLC** ($100 filing + $200 agent) for US billing.[1]
  - Register Czech trade license for EU defense eligibility.
- **Funding Actions:**
  - Apply for **Google Start Tier** ($2,000 credits).
  - Secure 2-3 **Penetration Testing / vCISO** contracts ($5k-$15k/mo). This revenue pays for the registered agent, domain, and basic administrative costs.
- **Technical Actions:**
  - Deploy the "Minimum Viable Scanner" (Cloud Run + Gemini Flash-Lite).
  - Use this internal tool to accelerate the consulting work (eating your own dog food).

## 6.2 Phase 2: MVP and The "Design Partner" Program (Months 6-12)

- **Objective:** Launch the IoT Ledger Alpha and secure first recurring product revenue.
- **Product Actions:**
  - Release the IoT Vulnerability Ledger API.
  - Populate the ledger with public NVD data enriched by the AI agents to demonstrate value.
- **Sales Actions:**
  - Convert consulting clients into **Design Partners**. Offer them the "SOC-in-a-box" for a low flat fee (e.g., $500/mo) in exchange for detailed feedback and case studies.
- **Strategic Actions:**
  - Apply for **SBIR Phase I** grants (via the US LLC if a US citizen co-founder is recruited, or utilizing the "Subcontractor" strategy with a US Prime).[1]
  - Register for the **Google Growth Academy: AI for Cybersecurity** (2026 cohort) to gain mentorship and investor visibility.[1]

## 6.3 Phase 3: Scale and Certification (Year 2+)

- **Objective:** Enterprise readiness and institutional funding.
- **Compliance:**
  - Invest accumulated consulting profits ($20k-$60k) into **SOC 2 Type I** certification. This is the "table stakes" for selling to mid-market US enterprises.[1]
- **Growth:**
  - Apply for the **Google "Scale" or "AI Scale" Tier** ($200k - $350k credits) to fund

the infrastructure for mass-market rollout.
    - Expand the sales team to target the "Mid-Market Gap" aggressively, leveraging the "SOC-in-a-box" value proposition.

### 6.4 Risk Management and Mitigation

- **Risk:** Running out of Credits.
    - *Mitigation:* The "Scale-to-Zero" architecture ensures that if revenue pauses, costs drop to near zero. The consulting revenue acts as a perpetual safety net.
- **Risk:** Regulatory Blockade (FOCI).
    - *Mitigation:* The "Dual-Track" structure (US Commercial vs. EU Defense) ensures that a blockage in one market does not kill the company. The focus on commercial markets first reduces reliance on slow government procurement cycles.
- **Risk:** AI Hallucination (False Positives).
    - *Mitigation:* The "Human-in-the-Loop" workflow for high-severity findings, and the use of the "Verification Agent" (Tier 3) that validates exploits in a sandbox before reporting them.

---

## Conclusion

The project organization plan for Idarti transforms the constraints of a bootstrapped, Czech-founded startup into a strategic advantage. By acknowledging the inability to compete on capital, Idarti competes on **architecture**—specifically, the cost-efficiency of Serverless, the scalability of DePIN, and the operational leverage of Agentic AI.

The plan addresses the critical market failures of the NVD and the bug bounty ecosystem not with incremental improvements, but with a fundamental redesign of how trust and intelligence are generated. The "Services-First" funding model provides the runway to build this vision without immediate dilution, while the rigorous separation of US and EU operations navigates the complex geopolitical reality of modern cybersecurity.

Ultimately, Idarti is not just building a product; it is building a **self-driving defense infrastructure**. By following this roadmap, utilizing the $1,250 in credits to spark the engine, Idarti can grow from a "consultant with a script" into a global platform that secures the autonomous future.

---

*End of Report.*

**Works cited**

1. Strategic Business Plan for a Bootstrapped Cybersecurity Startup_ IoT Security and Market Entry Analysis.pdf